

Frontend public robots.txt allows all routes

Severity: Low

Evidence: frontend/public/robots.txt

Risk: If the frontend static robots file overrides the backend robots endpoint, admin/private routes are not disallowed for crawlers.

Recommendation: Align frontend robots.txt with backend robots rules and disallow /admin, /dashboard, /login, /register, /reset-password, /api/admin, and /api/me.

Accidental empty .crdownload file in public folder

Severity: Low

Evidence: frontend/public/Unconfirmed 716710.crdownload

Risk: The file is empty, but public folders should not contain accidental browser download artifacts.

Recommendation: Delete accidental public files and add ignore rules/checks to keep them out of builds.

Upload pre-filter trusts client MIME type

Severity: Low

Evidence: backend/src/middleware/upload.ts:24-35;
backend/src/controllers/uploadController.ts:23-33

Risk: Sharp rejects invalid images later, but MIME type alone is client-controlled and should not be the first trust boundary.

Recommendation: Validate magic bytes and Sharp metadata before processing; add pixel-count limits to reduce decompression-bomb risk.

Strong Controls Already Present

- Authentication uses HTTP-only cookies plus CSRF protection.
- Access-token verification re-checks the user and role from the database.
- Refresh tokens are stored as hashes in database-backed sessions.
- Password reset tokens are hashed, expiring, and single-use.
- Prisma is used for database access; no practical raw SQL injection pattern was found in active code.
- Admin routes are protected by backend authentication and role middleware.
- Public contact/data requests are queued instead of automatically exporting or deleting accounts.
- Article body HTML is sanitized server-side and again client-side before rendering.